

Mount Kenya University

Unlocking Infinite Possibilities

UNIT:ETHICAL HACKING

NAME: EUGINE KIPCHIRCHIR

ADM NO: BSCCS/2024/53845

COURSE: BACHELOR OF SCIENCE IN INFORMATION TECHNOLOGY

DEPARTMENT: COMPUTING AND INFORMATICS

LECTURER : MICHAEL NYORO

SUBMISSION DATE: 4/6/2026

GIT HUB LINK: <https://github.com/smooth254-arch/BIT4939-Ethical-hacking-and-counter-measures.git>

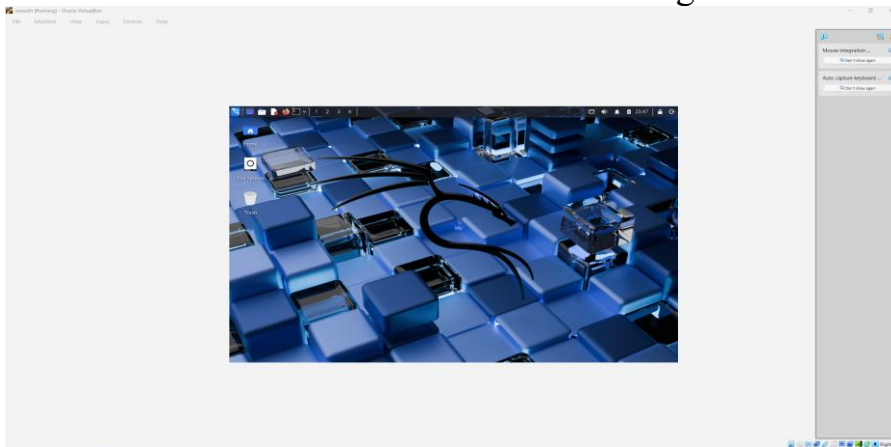
Table of Contents

TASK 1:Complete Installation	4
FootPrinting	4
2.DNS Information(dig/nslookup)	4
WEEK4:SCANNING NETWORKS	5
Port Scanning	5
Port Scanning Results.....	5
STEPS IN ETHICAL HACKING.....	5
1.Information gathering	5
A. Domain Registra.....	5
B.IP Adress.....	6
C. Email patterns used.....	6
D. Technologies used to run the website	6
SCANNING AND ENUMERATION	7
1.Scan open ports	7
2. Detect running services	7
3.Identify the OS used	7
4.Enumerate users & service	8
WEEK 6: VULNERABILITY ASSESSMENT AND SCANNING.....	8
Practical Task 1: Basic Vulnerability Scan	8
Observation	8
Recommendation for security improvement.....	8
Practical Task 2: Vulnerability Research Assignment.....	8
University Network.....	9
Small Business	9
Hospital	9
Financial Institution.....	9
Advanced Practical Task: Vulnerability Tracking Spreadsheet	10
Purpose of the Spreadsheet	10
Observation	10
Challenge Task: Vulnerability Management Framework.....	10
Asset Inventory	11
Vulnerability Scanning.....	11
Risk Assessment Process.....	11
Patch Management	11
Reporting Procedures	11
Continuous Monitoring	11
Week 7: Web Application Security and OWASP Top 10.....	11
Practical Task 1:OWASP Top 10 Research.....	11

1. Injection.....	11
2. Broken Access Control.....	12
3. Identification and Authentication Failures	12
4. Software and Data Integrity Failures	12
5. Security Logging and Monitoring Failures	13
6. Server-Side Request Forgery (SSRF).....	13
7. Security Misconfiguration.....	13
8. Vulnerable and Outdated Components.....	14
9. Cryptographic Failures.....	14
10. Insecure Design	14
Practical Task 2: Web Application Assessment	15
Potential Vulnerabilities Identified.....	16
Findings.....	16
Practical Task 3: Security Improvement Proposal	16
Authentication Controls	16
Input Validation Measures.....	16
Logging Mechanisms	17
Patch Management Strategy	17
Advanced Practical Task: Web Security Checklist	17
Authentication	17
Authorization.....	17
Input Validation	17
Session Management.....	17
Encryption	17
Logging	17
Configuration Management.....	18
Challenge Task: Secure Web Application Design Framework	18
1. Security Requirements	18
2. Threat Modeling	18
3. Secure Coding Practices.....	18
4. Testing Procedures	18
5. Deployment Controls	18
6. Monitoring and Incident Response	18
Creative Task: Perform a Basic Security Assessment Using Burp Suite.....	19
What I did.....	19
My Reflection.....	19

TASK 1: Complete Installation

Kalilinux on Oracle virtual box running



FootPrinting

1.whois look up

Testing site: scanme.nmap.org(made for learning)hence its safe target.I will be using my own router IP and my Windows host(Virtual box host only IP)

```
(smooth@kali)-[/home/smooth]
PS> whois scanme.nmap.org
Malformed request.
>>> Last update of WHOIS database: 2026-05-27T20:54:28Z <<<

Terms of Use: Access to Public Interest Registry WHOIS information is provide
d to assist persons in determining the contents of a domain name registration
record in the Public Interest Registry registry database. The data in this r
ecord is provided by Public Interest Registry for informational purposes only
, and Public Interest Registry does not guarantee its accuracy. This service
is intended only for query-based access. You agree that you will use this dat
a only for lawful purposes and that, under no circumstances will you use this
data to (a) allow, enable, or otherwise support the transmission by e-mail,
telephone, or facsimile of mass unsolicited, commercial advertising or solici
tations to entities other than the data recipient's own existing customers; o
r (b) enable high volume, automated, electronic processes that send queries o
r data to the systems of Registry Operator, a Registrar, or Identity Digital
except as reasonably necessary to register domain names or modify existing re
gistrations. All rights reserved. Public Interest Registry reserves the right
to modify these terms at any time. By submitting this query, you agree to ab
ide by this policy. The Registrar of Record identified in this output may ha
ve an RDNS service that can be queried for additional information on how to c
ontact the Registrant, Admin, or Tech contact of the queried domain name.

(smooth@kali)-[/home/smooth]
PS>
```

2.DNS Information(dig/nslookup)

```
(smooth@kali)-[/home/smooth]
PS> dig scanme.nmap.org

; <<>> DiG 9.20.15-2-Debian <<>> scanme.nmap.org
;; global options: +cmd
;; Got answer:
;; -->HEADER<-- opcode: QUERY, status: NOERROR, id: 8504
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 512
;; QUESTION SECTION:
;scanme.nmap.org.                IN      A

;; ANSWER SECTION:
scanme.nmap.org.                57      IN      A      45.33.32.156

;; Query time: 87 msec
;; SERVER: 192.168.8.1#53(192.168.8.1) (UDP)
;; WHEN: Wed May 27 23:58:17 EAT 2026
;; MSG SIZE rcvd: 60

(smooth@kali)-[/home/smooth]
PS>
```

All about IP address and DNS records

WEEK4:SCANNING NETWORKS

Port Scanning

```
(smooth@kali)-[/home/smooth]
PS> nmap -F scanme.nmap.org
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-28 00:24 EAT
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.062s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 98 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 4.60 seconds
```

Port Scanning Results

A fast scan was conducted using Nmap against the target scanme.nmap.org.

Findings

The scan identified were:

- Port 22/tcp open (SSH service)
- Port 80/tcp open (HTTP service)

The target host was active and reachable with low latency. Most other ports were filtered and did not respond.

STEPS IN ETHICAL HACKING

1.Information gathering

A. Domain Registra

```
(smooth@kali)-[/home/smooth]
PS> whois kefri.org
Domain Name: kefri.org
Registry Domain ID: REDACTED
Registrar WHOIS Server: http://whois.lexsynergy.com
Registrar URL: http://www.lexsynergy.com
Updated Date: 2025-09-17T11:04:51Z
Creation Date: 2001-09-20T16:10:17Z
Registry Expiry Date: 2026-09-20T16:10:17Z
Registrar: Lexsynergy Limited
Registrar IANA ID: 1466
Registrar Abuse Contact Email: abuse@lexsynergy.com
Registrar Abuse Contact Phone: +44.2081331319
Domain Status: clientDeleteProhibited https://icann.org/epp#clientDeleteProhibited
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Domain Status: clientUpdateProhibited https://icann.org/epp#clientUpdateProhibited
Name Server: ns1.kenet.or.ke
Name Server: ns2.kenet.or.ke
Name Server: ns3.kenet.or.ke
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://icann.org/wicf/
>>> Last update of WHOIS database: 2026-06-04T04:46:20Z <<<
```

B. IP Address

```
(smooth@kali)-[/home/smooth]
PS> dig kefri.org

; <<>> DiG 9.20.15-2-Debian <<>> kefri.org
;; global options: +cmd
;; Got answer:
;; -->HEADER<-- opcode: QUERY, status: NOERROR, id: 57284
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 512
;; QUESTION SECTION:
;kefri.org.                IN      A

;; ANSWER SECTION:
kefri.org.                 3600    IN      A      41.204.160.15

;; Query time: 124 msec
;; SERVER: 8.8.8.8#53(8.8.8.8) (UDP)
```

IP Address: 41.204.160.15

C. Email patterns used

```
(smooth@kali)-[/home/smooth]
PS> dig mx kefri.org

; <<>> DiG 9.20.15-2-Debian <<>> mx kefri.org
;; global options: +cmd
;; Got answer:
;; -->HEADER<-- opcode: QUERY, status: NOERROR, id: 22263
;; flags: qr rd ra; QUERY: 1, ANSWER: 7, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 512
;; QUESTION SECTION:
;kefri.org.                IN      MX

;; ANSWER SECTION:
kefri.org.                 3600    IN      MX      70 mta01.scanscope.net.
kefri.org.                 3600    IN      MX      30 mail2.scanscope.net.
kefri.org.                 3600    IN      MX      40 mail3.scanscope.net.
kefri.org.                 3600    IN      MX      20 mx2-eu.emailsecurity.app.
kefri.org.                 3600    IN      MX      50 kefri-org.mail.protection.outlook.com.
kefri.org.                 3600    IN      MX      60 mail1.scanscope.net.
kefri.org.                 3600    IN      MX      10 mx1-eu.emailsecurity.app.

;; Query time: 152 msec
;; SERVER: 8.8.8.8#53(8.8.8.8) (UDP)
;; WHEN: Thu Jun 04 07:55:37 EAT 2026
;; MSG SIZE rcvd: 255
```

We had 7 answers and kefri.org uses Microsoft outlook for email services

D. Technologies used to run the website

```
(smooth@kali)-[/home/smooth]
PS> whatweb https://kefri.org
https://kefri.org [403 Forbidden] Apache, Country[KENYA][KE], HTTPServer[Apache], IP[41.204.160.15], Title[403 Forbidden]
```

This means that Apache is their webserver software running the website .403 forbidden means the sever understood the request but it refuse to provide the requested resource. This usually mean that directory browsing is disables/access restrictions are configured/the site blocks certain automated requests. This is usually done for security purposes.

SCANNING AND ENUMERATION

1.Scan open ports

```
(smooth@kali)-[/home/smooth]
PS> nmap kefri.org
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-04 08:25 EAT
Nmap scan report for kefri.org (41.204.160.15)
Host is up (0.0050s latency).
rDNS record for 41.204.160.15: cp-uon.kenet.or.ke
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https

Nmap done: 1 IP address (1 host up) scanned in 11.42 seconds
```

2. Detect running services

```
(smooth@kali)-[/home/smooth]
PS> nmap -sV kefri.org
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-04 08:47 EAT
Nmap scan report for kefri.org (41.204.160.15)
Host is up (0.0055s latency).
rDNS record for 41.204.160.15: cp-uon.kenet.or.ke
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE  VERSION
80/tcp    open  tcpwrapped
443/tcp   open  tcpwrapped

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
.
Nmap done: 1 IP address (1 host up) scanned in 24.42 seconds
```

3. Identify the OS used

```
(smooth@kali)-[/home/smooth]
PS> sudo nmap -O kefri.org
[sudo] password for smooth:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-04 08:51 EAT
Nmap scan report for kefri.org (41.204.160.15)
Host is up (0.0025s latency).
rDNS record for 41.204.160.15: cp-uon.kenet.or.ke
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: switch
Running (JUST GUESSING): Cisco embedded (88%)
OS CPE: cpe:/h:cisco:catalyst_1900
Aggressive OS guesses: Cisco Catalyst 1900 switch (88%)
No exact OS matches for host (test conditions non-ideal).

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.83 seconds
```

4.Enumerate users & service

```
(smooth@kali)-[/home/smooth]
PS> nmap --script smb-enum-users -p 445 41.204.160.15
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-04 09:24 EAT
Nmap scan report for cp-uon.kenet.or.ke (41.204.160.15)
Host is up (0.00058s latency).

PORT      STATE      SERVICE
445/tcp    filtered  microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 1.40 seconds

(smooth@kali)-[/home/smooth]
PS> nmap -sV 41.204.160.15
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-04 09:25 EAT
Nmap scan report for cp-uon.kenet.or.ke (41.204.160.15)
Host is up (0.0044s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE      SERVICE      VERSION
80/tcp    open       tcpwrapped
443/tcp    open       tcpwrapped

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 18.83 seconds
```

WEEK 6: VULNERABILITY ASSESSMENT AND SCANNING

Practical Task 1: Basic Vulnerability Scan

```
(smooth@kali)-[/home/smooth]
PS> nmap localhost
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-18 12:54 EAT
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0000030s latency).
Other addresses for localhost (not scanned): ::1
All 1000 scanned ports on localhost (127.0.0.1) are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap done: 1 IP address (1 host up) scanned in 0.14 seconds
```

Active host:127.0.0.1

Open ports: No open ports were found and all scanned ports were closed.

Observation

I did not find any network services running on the localhost system when I did the scan. This means the localhost system is not very open, to the network so it is not very exposed.

Recommendation for security improvement

Regular checks of the system and keeping everything up to date will help keep the system secure.

Practical Task 2: Vulnerability Research Assignment

CVE Number	Description	Severity	Potential Impact	Mitigation Strategy
CVE-2025-33053	A WebDAV remote code execution vulnerability affecting Microsoft Windows systems.	High (CVSS 8.8)	Attackers can execute malicious code remotely and gain unauthorized access.	Apply Microsoft's June 2025 security updates and disable unnecessary WebDAV services. (TechTarget)

CVE-2025-33073	A vulnerability affecting Windows SMB services.	High (CVSS 8.8)	Could allow attackers to compromise systems through network-based attacks.	Install Microsoft security patches and restrict SMB exposure. (Microsoft Learn)
CVE-2025-21479	A Qualcomm Adreno GPU vulnerability affecting Android devices.	High	May allow attackers to exploit affected devices and compromise data.	Install Android security updates provided by device vendors. (Reddit)
CVE-2025-53770	A Microsoft SharePoint Server remote code execution vulnerability actively exploited in the wild.	Critical (CVSS 9.8)	Unauthorized attackers can execute code and compromise SharePoint servers.	Apply Microsoft security updates and follow vendor mitigation guidance. (Reddit)
CVE-2025-7029	A Gigabyte UEFI firmware vulnerability that can bypass Secure Boot protections.	High (CVSS 8.2)	Attackers with elevated privileges can install persistent firmware backdoors.	Update motherboard firmware to the latest secure version. (Tom's Hardware)

Practical Task 3: Organizational Vulnerability Assessment Plan

University Network

Includes student and staff computers, servers, and Wi-Fi. The assessment covers academic systems, administrative servers, and network devices. Tools: Nmap and OpenVAS.

Small Business

Consists of workstations, routers, and business applications. The assessment covers endpoint devices and network infrastructure. Tools: Nmap and Nessus. Assessments are done quarterly, with reports submitted to managers.

Hospital

Includes patient records, medical applications and communication systems. The assessment focuses on medical databases, diagnostic tools and connected equipment. Tools: OpenVAS and Qualys. Assessments are conducted monthly.

Financial Institution

Consists of banking systems, transaction servers, and customer databases. The assessment covers financial applications, databases, and network infrastructure. Tools: Nessus and Qualys. Assessments are performed weekly, with reports sent to risk management and cybersecurity teams

Advanced Practical Task: Vulnerability Tracking Spreadsheet

Figure 4: Vulnerability Tracking Spreadsheet

Vulnerability Name	Risk Level	Status	Assigned Personnel	Resolution Date
Open SSH Port	Medium	Open	IT Administrator	25/06/2026
Weak Password Policy	High	In Progress	Security Officer	28/06/2026
Outdated Web Browser	Medium	In Progress	System Administrator	30/06/2026
Missing Security Updates	Critical	In Progress	Patch Management Team	22/06/2026
Firewall Misconfiguration	High	In Progress	Network Engineer	20/06/2026

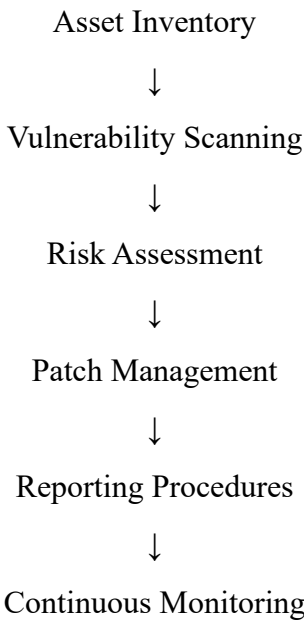
Purpose of the Spreadsheet

The vulnerability tracking spreadsheet is used to monitor identified vulnerabilities throughout their lifecycle. It records the risk level, remediation status, responsible personnel and expected resolution dates to ensure vulnerabilities are addressed in a timely manner.

Observation

The spreadsheet provides a structured method for tracking and managing vulnerabilities. It enables security teams to prioritize critical issues, assign responsibilities, and monitor remediation progress effectively.

Challenge Task: Vulnerability Management Framework.



Asset Inventory

Step one is to identify and maintain a database of all organizational assets, such as servers, workstations, network devices, databases, and applications. This makes sure that all assets needing security attention are identified.

Vulnerability Scanning

We periodically perform vulnerability scanning with tools like Nmap, OpenVAS, or Nessus to find security issues, misconfigurations, and outdated software within the environment.

Risk Assessment Process

Discovered vulnerabilities are evaluated based on their severity, likelihood of exploitation, and potential business impact. This helps prioritize remediation efforts according to risk levels.

Patch Management

Applying security patches, software updates, and configuration changes to mitigate identified vulnerabilities. Timely patching reduces the chances of successful attacks.

Reporting Procedures

All findings are documented in vulnerability reports that include a description of the vulnerability, severity ratings, affected systems, and recommended remediation actions. Reports are distributed to relevant stakeholders for decision-making.

Continuous Monitoring

All findings are documented in vulnerability reports that include a description of the vulnerability, severity ratings, affected systems, and recommended remediation actions. Reports are distributed to relevant stakeholders for decision-making.

Consists of banking systems, transaction servers, and customer databases. The assessment covers financial applications, databases, and network infrastructure. Tools: Nessus and Qualys. Assessments are performed weekly, with reports sent to risk management and cybersecurity teams

Week 7: Web Application Security and OWASP Top 10

Practical Task 1:OWASP Top 10 Research

1. Injection

Injection vulnerabilities occur when untrusted user input is interpreted as commands or queries by an application. Example: An attacker performs SQL Injection to bypass a login page.

Impact:

1. Unauthorized database access.
2. Data theft or modification.
3. Complete system compromise.

Prevention:

1. Use parameterized queries and prepared statements.
2. Validate and sanitize user input.
3. Apply input filtering.

2. Broken Access Control

Broken Access Control occurs when users can perform actions or access resources beyond their authorized permissions. Example: A normal user accesses another user's account or an administrator's page by changing the URL.

Impact:

- Unauthorized access to sensitive information.
- Modification or deletion of data.
- Loss of confidentiality and integrity.

Prevention:

- Implement role-based access control (RBAC).
- Enforce authorization checks on every request.
- Apply the principle of least privilege.

3. Identification and Authentication Failures

Identification and Authentication Failures occur when weak authentication mechanisms allow attackers to gain unauthorized access. Example: Allowing weak passwords or unlimited login attempts.

Impact:

- Account compromise.
- Unauthorized access.
- Identity theft.

Prevention:

- Enforce strong password policies.
- Enable Multi-Factor Authentication (MFA).
- Securely manage user sessions.

4. Software and Data Integrity Failures

Software and Data Integrity Failures occur when software updates, code, or data cannot be trusted because their integrity has not been verified. Example: Installing software updates from untrusted sources without verifying their integrity.

Impact:

- Malware installation.
- Data manipulation.
- System compromise.

Prevention:

- Verify software integrity using digital signatures.
- Secure CI/CD pipelines.
- Only use trusted software sources.

5. Security Logging and Monitoring Failures

Security Logging and Monitoring Failures occur when security events are not properly logged, monitored, or responded to. Example: Repeated failed login attempts are not recorded or monitored.

Impact:

- Delayed detection of attacks.
- Difficulty investigating incidents.
- Increased damage from security breaches.

Prevention:

- Enable comprehensive logging.
- Monitor security events continuously.
- Develop an incident response plan.

6. Server-Side Request Forgery (SSRF)

Server-Side Request Forgery (SSRF) occurs when an attacker tricks a server into making requests to unintended internal or external resources. Example: A web application fetches a URL supplied by a user, allowing access to internal services.

Impact:

- Exposure of internal systems.
- Data leakage.
- Cloud service compromise.

Prevention:

- Validate and whitelist URLs.
- Restrict outbound network requests.
- Isolate internal services using network segmentation.

7. Security Misconfiguration

Security Misconfiguration occurs when servers, applications, or databases are configured insecurely. Example: Using default administrator passwords or leaving unnecessary services enabled.

Impact:

- Unauthorized system access.
- Information disclosure.
- Increased attack surface.

Prevention:

- Remove default credentials.
- Disable unused services.
- Regularly audit system configurations.

8. Vulnerable and Outdated Components

Using vulnerable and outdated components means relying on software, libraries, or frameworks with known security vulnerabilities. Example: Running an outdated web framework with publicly known exploits.

Impact:

- Exploitation of known vulnerabilities.
- System compromise.
- Data breaches.

Prevention:

- Update software regularly.
- Apply security patches promptly.
- Monitor third-party dependencies.

9. Cryptographic Failures

Cryptographic Failures occur when sensitive information is not properly protected using encryption. Example: Storing user passwords in plain text or transmitting sensitive data without HTTPS.

Impact:

- Exposure of confidential information.
- Identity theft.
- Financial losses.

Prevention:

- Use strong encryption algorithms.
- Securely manage encryption keys.
- Enforce HTTPS for all communications.

10. Insecure Design

Insecure Design refers to security weaknesses caused by poor application design rather than coding errors. Example: An online banking application that does not limit the number of passwords reset attempts.

Impact:

- Increased likelihood of successful attacks.
- Business logic abuse.
- Security weaknesses throughout the application.

Prevention:

- Follow secure-by-design principles.
- Conduct threat modeling.
- Perform security reviews during development.

Practical Task 2: Web Application Assessment

Fig1.OWASP Juice Shop home page.

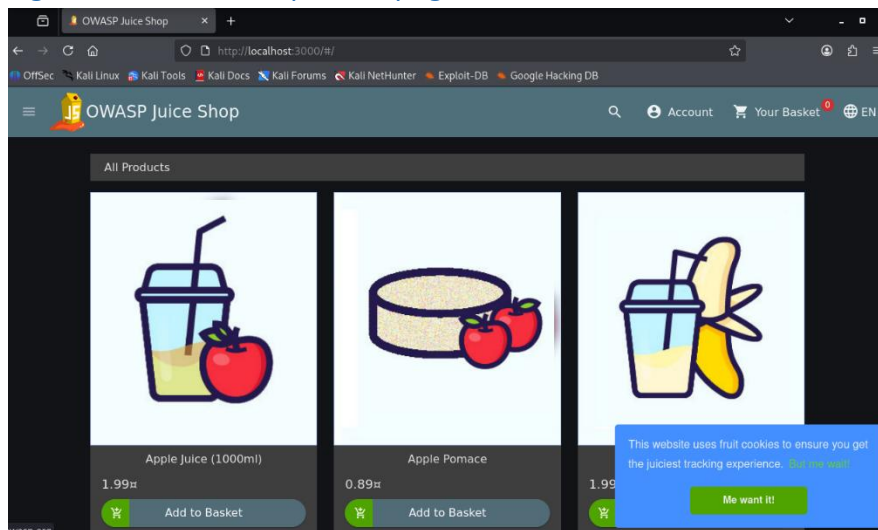


Fig2. Login Form

A screenshot of the 'Login' form in the OWASP Juice Shop. The form is on a dark background. It has a title 'Login' at the top. Below it are two input fields: 'Email*' and 'Password*'. The password field has an eye icon to toggle visibility. Below the password field is a link 'Forgot your password?'. There are two buttons: a blue 'Log in' button and a checkbox labeled 'Remember me'. Below these is a horizontal line with the word 'or' in the center. Underneath is a green button with the Google logo and the text 'Log in with Google'. At the bottom, there is a link 'Not yet a customer?'.

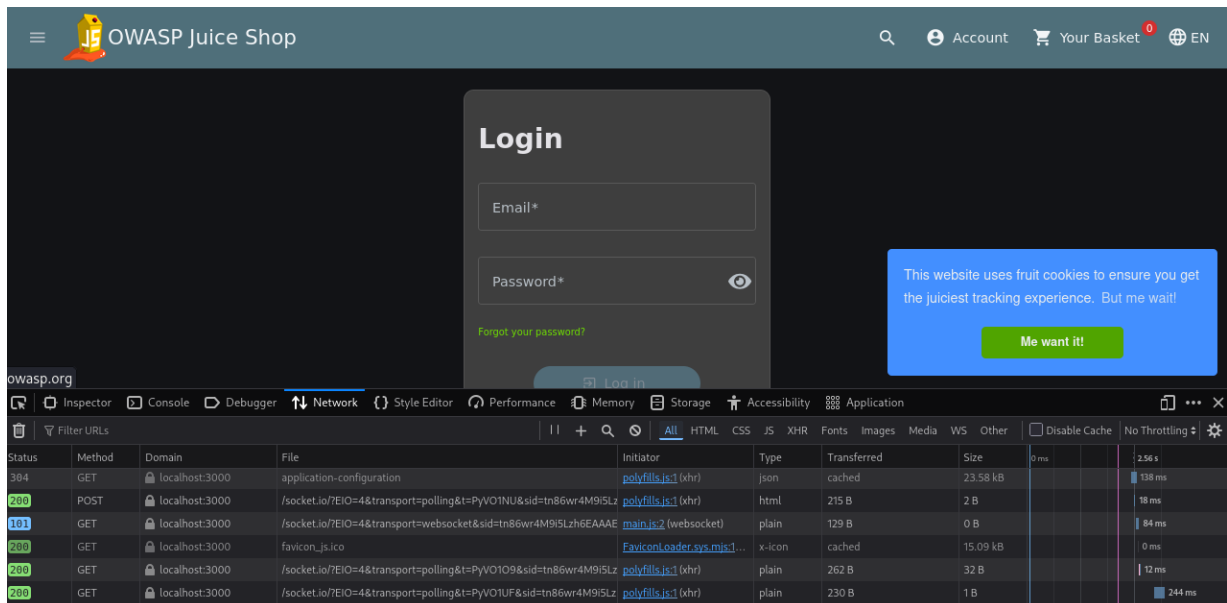
Fig3. Registration Form

A screenshot of the 'User Registration' form in the OWASP Juice Shop. The form is on a dark background. It has a title 'User Registration' at the top. Below it are several input fields: 'Email*', 'Password*', 'Repeat Password*', 'Security Question *' (a dropdown menu), and 'Answer*'. The 'Password*' field has a character count '0/20' and a hint 'Password must be 5-40 characters long.'. The 'Repeat Password*' field has a character count '0/40'. There is a toggle switch for 'Show password advice'. Below the form fields is a blue 'Register' button. At the bottom, there is a link 'Already a customer?'.

Fig4. Search Function



Fig5. Browser Developer Tools



Potential Vulnerabilities Identified

1. Weak passwords could allow unauthorized access if strong password policies are not enforced.
2. Input fields require proper server-side validation to prevent attacks such as SQL Injection and Cross-Site Scripting (XSS).
3. Session cookies should use the **Secure** and **HttpOnly** attributes to protect user sessions.
4. Missing or weak security headers could expose the application to common web-based attacks.
5. Outdated software components may introduce known vulnerabilities if security updates are not applied.

Findings

OWASP Juice Shop is an intentionally vulnerable web application used for web security training and testing. It provides a safe environment for identifying and analyzing common web application vulnerabilities.

Practical Task 3: Security Improvement Proposal

Authentication Controls

1. Implement Multi-Factor Authentication (MFA).
2. Enforce strong password policies.
3. Lock accounts after multiple failed login attempts.

Input Validation Measures

1. Validate all user input on both the client and server sides.

2. Use parameterized queries to prevent SQL injection.
3. Sanitize input to reduce Cross-Site Scripting (XSS) risks.

Logging Mechanisms

1. Log user login attempts and security events.
2. Monitor suspicious activities.
3. Regularly review system logs.

Patch Management Strategy

1. Keep the application and server up to date.
2. Apply security patches promptly.
3. Remove outdated or unused software components.

Advanced Practical Task: Web Security Checklist

Authentication

1. Use strong passwords.
2. Enable Multi-Factor Authentication (MFA).
3. Lock accounts after repeated failed login attempts.

Authorization

1. Implement role-based access control.
2. Apply the principle of least privilege.

Input Validation

1. Validate all user inputs.
2. Sanitize user data.
3. Use parameterized queries to prevent SQL injection.

Session Management

1. Use secure session IDs.
2. Enable **Secure** and **HttpOnly** cookies.
3. Automatically expire inactive sessions.

Encryption

1. Use HTTPS for all communications.
2. Encrypt sensitive data.
3. Store passwords using secure hashing algorithms.

Logging

1. Log login attempts and security events.
2. Monitor suspicious activities.

3. Review logs regularly.

Configuration Management

1. Remove default passwords.
2. Disable unnecessary services.
3. Keep software and systems updated with security patches.

Challenge Task: Secure Web Application Design Framework

1. Security Requirements

1. Define authentication and authorization requirements.
2. Protect sensitive user data.
3. Ensure data confidentiality, integrity, and availability.

2. Threat Modeling

1. Identify valuable assets.
2. Identify potential threats and attackers.
3. Assess possible attack vectors and risks.

3. Secure Coding Practices

1. Validate all user inputs.
2. Use parameterized queries.
3. Encrypt sensitive data.
4. Follow secure coding standards.

4. Testing Procedures

1. Perform regular vulnerability assessments.
2. Conduct penetration testing.
3. Review source code for security flaws.
4. Test input validation and authentication.

5. Deployment Controls

1. Configure servers securely.
2. Enable HTTPS.
3. Keep systems updated with security patches.
4. Restrict unnecessary services and access.

6. Monitoring and Incident Response

1. Continuously monitor system activity.
2. Maintain security logs.
3. Detect and respond to incidents promptly.

4. Regularly back up critical data.

Creative Task: Perform a Basic Security Assessment Using Burp Suite

Fig1. Burp Suite intercepting an HTTP request.

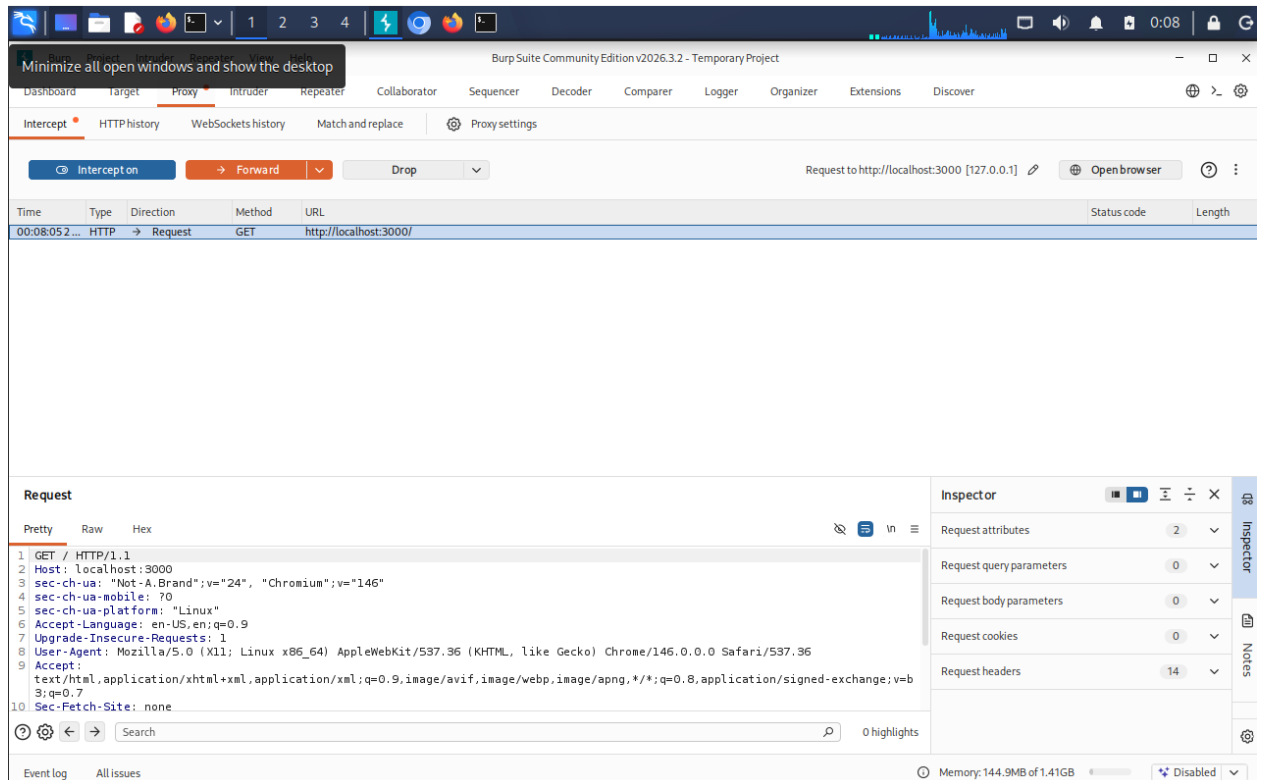
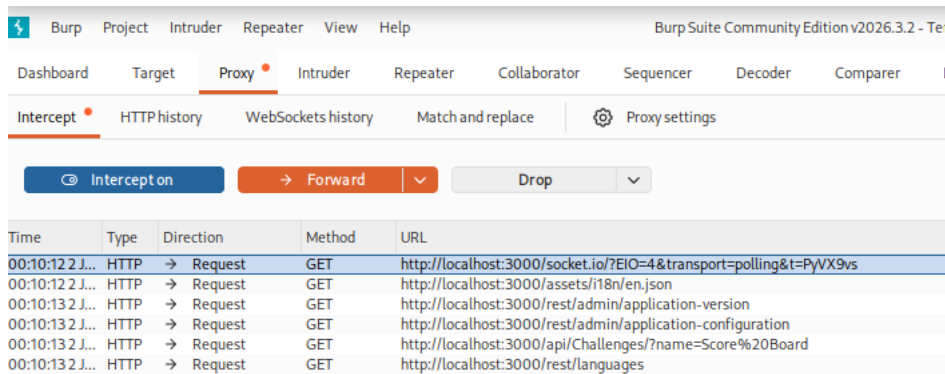


Fig2. After forwarding



What I did

Configured Burp Suite as a proxy and intercepted HTTP requests from OWASP Juice Shop. Analyzed request details, including headers, cookies, and parameters, to understand browser-server communication and basic web application security testing in a safe laboratory environment.

My Reflection

This week's practical enhanced my understanding of web application security and the OWASP Top 10 vulnerabilities. I learned how to assess a web application, identify potential security risks, and use Burp Suite to inspect HTTP requests in a safe and controlled environment.